

Blossom Login & Security Training — Expanded Q&A Source (25 Sections)

Purpose: Training-style reference designed for retrieval (RAG) and agent answers. Content is detailed so each chunk can stand on its own.

Scope: Signup and access setup, identity checks, verification (email/SMS), login, password policy and resets, session and device trust, lockout/unlock, username recovery, contact updates, holidays, troubleshooting, admin SOPs, alerts, audit, and compliance.

1. Principles & Safety (LP-001)

Intent: Keep members safe while reducing friction. - Speak plainly, be kind, and assume positive intent. Offer to show step-by-step when a user seems unsure. - Never request or echo verification codes, full reset links, or full government IDs (use last-4 only where appropriate). - Prefer self-service first. Escalate to admin only when identity cannot be confirmed online or the member lost access to contact methods. - Set expectations: explain what happens next and how long it takes. On federal holidays, delivery can be slower.

2. Definitions & Roles (LP-002)

- Member: End user with personal or business profile. May hold multiple accounts.
 - Admin: Authorized staff who can update contact data, unlock accounts, and trigger resets. Actions are logged.
 - Device trust: A 30-day token tying browser/device to a member; requires OTP when missing/expired.
 - Sensitive data: Passwords, OTP codes, reset links, government IDs, full card numbers. Handle with minimum necessary exposure.
-

3. Personas & Contexts (LP-003)

- Everyday Member: Low technical expertise, signs in from a single device; needs gentle guidance.
 - Power User: Uses multiple devices/browsers; often hits device trust and OTP edges.
 - New Joiner: In signup/onboarding; likely needs help with verification and first sign-in.
 - Call-in Member: Has partial access (e.g., email but no phone) and requires clear next steps.
-

4. Eligibility for Online Access (LP-004)

Preconditions - A member profile exists with email and phone on file. - Member can access at least one channel (email or phone).

Denials - Missing contact methods → guide to add/update via admin after identity verification. - Fraud hold or unresolved security review → escalate to security team.

5. Signup — Web (LP-800)

Inputs: Legal name, DOB, ID token (e.g., last 4 of SSN), optional member number. Process: 1) Open Sign Up. 2) Enter identity details and pass captcha if presented. 3) Choose username and password (see LP-101). Real-time checks show policy compliance. 4) Verify email with 6-digit code; allow resend after 10 minutes. 5) Verify phone via SMS (prefer) or voice; allow resend after 60 seconds. 6) When both are verified, first sign-in is enabled. Success Criteria: Both channels verified; account enters Active state. Failure Modes: Wrong contact on file; expired codes; blocked domain; carrier delays.

6. Signup — Mobile App (LP-801)

- Steps mirror web. If the device supports auto-fill OTP, ensure the code is not exposed in screenshots.
 - In-app browser deep-links the reset/verify flows. Provide a “copy link” fallback.
 - Push notifications for OTP are optional; treat them as a convenience channel only.
-

7. Username Rules (LP-102)

- Length 4–32; allowed: letters, numbers, dot, hyphen, underscore.
 - Must not equal password or include full government ID.
 - Avoid email address as username to reduce exposure.
 - Reject trivial forms (e.g., "user", "test", bank name).
-

8. Password Policy (LP-101)

Requirements - Length 8–64. - At least 1 uppercase, 1 lowercase, 1 number, 1 symbol. - Disallow leading/trailing spaces; disallow reuse of last 5 passwords. - No forced rotation; rotate only on risk (compromise, phishing, member request). Guidance: Favor passphrases (two words + digit + symbol). Do not reuse work or email passwords.

9. Password Reset — Web (LP-701)

Preconditions: Known username and verified email on file. Steps: 1) Click Forgot password. 2) Enter username + verified email; solve captcha. 3) Receive reset link (expires in 30 minutes). 4) Open link; set a policy-compliant password; confirm. 5) Sign in; if device is unrecognized, complete OTP. Errors: Link expired/used; rate limit hit; email bounces. Remedies: Send a new link; confirm email on file; check spam; try another device.

10. Password Reset — Mobile (LP-702)

- Equivalent to web; if the email client blocks the link, long-press to copy into browser.
 - Warn against forwarding reset emails. Link is single-use and bound to username.
-

11. Reset Link Handling (LP-703)

- Single-use; expires in 30 min; bound to username + nonce.
 - If clicked twice: show friendly message and offer Send new link.
 - Do not surface token or full link in support channels.
-

12. OTP Overview (LP-300)

- 6-digit codes; expire in 10 min; resend every 60 s.
 - Triggers: first sign-in on new device/browser, cookies cleared, 30-day trust expired, unusual activity.
 - Delivery: SMS or email (only verified channels). Prefer SMS for speed; email as fallback.
-

13. OTP Troubleshooting (LP-301)

Checklist - Verify contact on file; ask member to confirm last 2 letters of email domain (not full address). - Check spam/junk; carrier signal; short code blocks. - Switch channel (SMS↔Email). Advise waiting a full minute before resending. - Phone number changed? Update in Profile; until then use email verification. - No access to both channels → escalate to admin for contact update after identity verification.

14. Remember This Device (LP-401)

- Opt-in 30-day device trust stored via cookie + local storage.
 - Clearing cookies, using incognito, or switching browsers ends trust.
 - Recommend not trusting shared/public devices.
 - Members can review and revoke trusted devices in Profile (see LP-403).
-

15. Sessions & Timeouts (LP-402)

- Idle timeout: 15 min; session invalidates silently with gentle prompt to sign in again.
 - Absolute timeout: 8 h regardless of activity.
 - Sign out clears session but not device trust.
 - Display last sign-in time and location approximation for awareness.
-

16. Device Trust Management (LP-403)

Member Controls - View trusted devices list. - Revoke any device to force OTP on next sign-in. - Auto-revoke devices not used for 90 days. Admin View: Read-only device list with timestamps; cannot impersonate device trust.

17. Lockout Policy (LP-201)

- Lock after 3 consecutive failed sign-in attempts.
 - Auto-clear after 15 min, but encourage reset if unsure of password.
 - Lockout emails are sent to notify members of repeated failures.
-

18. Self-Unlock (LP-202)

Path 1) Start password reset. 2) Set compliant password via the email link. 3) Sign in successfully; lock clears automatically. Edge Cases: Lost email access → admin unlock path; see LP-203.

19. Admin Unlock SOP (LP-203)

Preconditions: Member cannot access email/phone or self-unlock failed. Steps: 1) Verify identity (government ID or equivalent token + knowledge-based questions). 2) Clear lockout flag. 3) Require a password reset before next sign-in. 4) Log actor, time, member ID, reason; send member a security notification.

20. Username Recovery (LP-500)

Self-Service 1) Click Forgot username. 2) Provide verified email + ID token (e.g., last 4 SSN). 3) System emails the username to the verified address. Admin Path: If email access is lost, update email after identity verification. Log the change.

21. Contact Update SOP (LP-1200)

When: Wrong email/phone on file, or member changed carriers. Steps: 1) Verify identity. 2) Update email or phone. 3) Send test OTP to confirm deliverability. 4) Ask member to sign in. 5) Log changes with reason code (e.g., "contact correction").

22. Email Deliverability Playbook (LP-1300)

- Ask members to whitelist the sender and check spam.
 - For corporate domains, recommend IT allow-listing the noreply sender.
 - Respect resend pacing; avoid flooding which triggers filters.
 - Use a clean, descriptive subject ("Blossom verification code") and recognizable sender name.
-

23. Security Alerts & Notifications (LP-404)

- Notify on: new device sign-in, password change, contact update, admin unlock.
 - Provide opt-in weekly sign-in summary. Allow unsubscribe from summaries (not from security notices).
 - Include "If this wasn't you" links pointing to reset/help routes.
-

24. Holidays & Timing (LP-900)

- Services run daily; delivery speed can drop on US federal holidays.
 - Use a Holidays API to set expectations (e.g., "Verification SMS may take a few extra minutes today").
 - Advise members to wait 10 minutes before resending, then try alternate channel.
-

25. Audit, Logging & Retention (LP-1500)

- Log admin actions: contact updates, unlocks, PIN resets, policy exceptions.
 - Capture actor, timestamp, member ID, action, reason, and result.
 - Retain logs 12 months minimum; provide export on compliance request.
 - Regularly review for anomalies (e.g., multiple unlocks by same admin in short window).
-

End of training content.